

AI Audit Report — Mẫu 5 mục cho mỗi Artifact

Phụ lục bắt buộc đính kèm cho mọi bài tập có dùng AI (HW#01–HW#06, Seminar).

Tài liệu được biên soạn lại từ Med Kharbach, PhD (2026) — Mẫu Chính sách Sử dụng AI cho Giáo dục Đại học. Giấy phép CC BY-NC-SA 4.0. Phiên bản này được FIT@HCMUS điều chỉnh cho môn CS423 / CSC15003 Kiểm chứng Phần mềm.

1. Thông tin Sinh viên

Mục	Giá trị
Họ tên sinh viên (in hoa):	HUỖNH SĨ LUÂN
MSSV:	23127086
Lớp / Khóa:	23CLC01
Mã bài tập (ví dụ HW#00, HW#02):	HW#02
Ngày làm bài:	28/06/2026
Công cụ AI đã dùng:	Gemini 3.5 Flash
Công cụ AI đã dùng:	☒ Có ☐ Không

2. Hướng dẫn (đọc trước khi điền)

- Thêm 1 hàng cho mỗi artifact AI sinh (test case, script, checklist, OpenAPI spec, JMeter plan...).
- Dán nguyên văn prompt — KHÔNG paraphrase.
- Dán nguyên văn output AI (hoặc kèm screenshot có chú thích trong báo cáo).
- Gắn nhãn: VALID / INVALID / INCOMPLETE.
- Lý do phải dẫn chiếu slide, mục ISTQB, hoặc RFC kỹ thuật.
- Hiển thị bản sửa với phần thay đổi được tô sáng.
- Hàng mẫu in nghiêng — thay trước khi nộp.

3. Bảng Audit — 1 hàng / artifact

(1) Prompt + Công cụ	(2) Output AI	(3) Verdict	(4) Lý do (ISTQB)	(5) Bản SV sửa
Tool: Gemini 3.5 Flash Thời gian: 14:32 22/06/2026 Prompt: "Trên đây là nội dung tài liệu yêu cầu bài tập HW02"	Dưới đây là tóm tắt những điểm cốt lõi và mang tính quyết định nhất mà bạn cần lưu ý để hoàn thành xuất sắc đề án này: 1. Nguyên tắc làm việc với AI (AI-First & Human-Verified) Không dùng prompt "mì ăn liền": Bạn không được yêu cầu AI tạo test case	VALID	AI đã tóm tắt chính xác các yêu cầu nghiệp vụ và cấu trúc của bài tập lớn theo mô tả trong tài liệu đề bài, hỗ trợ tốt cho việc	Sinh viên không cần chỉnh sửa do AI đã tóm tắt đầy đủ và chính xác tất cả các điểm cốt lõi của đề bài.

kiểm thử phần mềm. Hãy đọc kỹ toàn bộ nội dung này, hiểu rõ bối cảnh, kỹ thuật yêu cầu, danh sách các tính năng của SUT (EShop), cách thức làm bài và định dạng nộp bài. Sau đó, hãy tóm tắt lại cho tôi những điểm cần lưu ý nhất"	bằng một câu lệnh chung chung. Phải dẫn dắt AI đi qua từng bước của kỹ thuật Domain Testing và Boundary Value Analysis (BVA) như đã học. Trách nhiệm rà soát: Kết quả của AI phải được bạn kiểm duyệt và chỉnh sửa. Tuyệt đối không nộp raw output từ AI. AI Gap Analysis (Phân tích khoảng trống AI): Nếu AI bỏ sót test case hoặc bug, bạn phải báo cáo và giải thích lý do (do prompt chưa tốt, do giới hạn của tool, hay do tính năng quá phức tạp). 2. Chiến lược chọn tính năng (SUT) Quy tắc 4x1: Chọn chính xác 4 features, mỗi feature thuộc một Pool khác nhau (A, B, C, và D). Nguyên tắc độc quyền: Không được chọn trùng feature với bất kỳ thành viên nào trong nhóm. Tận dụng thế mạnh: Đối với Pool D (Mobile App), những kinh nghiệm xử lý logic và giao diện ứng dụng di động native thực tế sẽ là lợi thế cực kỳ lớn để bạn thiết kế các test case biên sát với trải nghiệm người dùng, dễ dàng "bắt" được các edge cases mà AI có thể bỏ qua. 3. Quy trình thực thi & Báo cáo Thiết kế Test Case chi tiết: Áp dụng và giải thích rõ từng bước (step-by-step) cách bạn dùng Domain Testing và BVA. Có thể tự bổ sung thêm test case ngoài AI để đảm bảo độ bao phủ. Quản lý Bug: Bug tìm được phải nằm trong file báo cáo (Markdown) VÀ được tạo thành các Issue trên GitHub của nhóm (bắt buộc đính kèm ảnh chụp màn hình). Git Commit Log: Trạng thái công việc phải được commit liên tục qua từng		định hình phạm vi kiểm thử.	
---	--	--	------------------------------------	--

	bước kiểm thử của từng tính năng. Cuối cùng, xuất toàn bộ log này ra một file text. 4. Hồ sơ minh bạch AI (Bắt buộc & Quan trọng) AI Audit Report: Ghi chép toàn bộ lịch sử làm việc với AI (Tên tool, thời gian, Prompt, Output). Đề bài khuyến khích bạn viết một "Agent Skill" để tự động hóa việc gom log này. AI Critique (200 - 300 từ): Đoạn văn phê bình AI. Trả lời thẳng vào vấn đề: AI đã sai, thiên kiến hoặc thiếu sót ở đâu? Tại sao nó trượt mất lỗi đó? Bạn rút ra được nguyên lý gì khi cộng tác với AI? 5. Yêu cầu nộp bài cực kỳ khắt khe Định dạng tên file: <StudentID>_HW02_AI_DomainTesting_<SelfAssessedGrade>.zip (Ví dụ: 25127001_HW02_AI_DomainTesting_090.zip). Thành phần gói nộp (.zip): 1. Main report (Markdown + PDF) cho cả Domain và BVA. 2. Bug report (kèm ảnh chụp từ GitHub Issues). 3. AI Critique & AI Audit Report (Markdown + PDF). 4. Git commit log (file text). 5. File README.md (chứa bảng tự chấm điểm và Báo cáo tổng kết số lượng test case, bugs, link video YouTube demo). Kỷ luật thép: Không nhận bài nộp trễ. Thiếu bất kỳ tài liệu nào sẽ nhận 0 điểm. Copy bài hoặc copy prompt của nhau sẽ dẫn đến điểm 0 cho cả hai. Bạn muốn chúng ta bắt đầu chọn tính năng cho từng Pool, hay muốn tôi hỗ trợ thiết lập trước một bộ khung thư mục và file chuẩn chỉnh để quá trình làm bài không bị sót bất cứ tài liệu nào?			
--	--	--	--	--

Tool: Gemini 3.5 Flash Thời gian: 7:11 23/06/2026 Prompt: " Tôi đang thực hiện kỹ thuật kiểm thử miền trị cho tính năng "Forgot password and password reset" của EShop. Luồng hoạt động gồm: 1. Người dùng yêu cầu nhận mã đặt lại mật khẩu qua email. 2. Backend sinh mã OTP 4 chữ số gửi qua email. 3. Người dùng nhập mã OTP để đổi mật khẩu mới. Hãy giúp tôi xác định các phân hoạch tương đương (Equivalence Partitions) cho các trường đầu vào: - email (hợp lệ trong DB, hợp lệ nhưng không trong DB, sai định dạng, rỗng) - resetToken (trùng khớp, sai số, rỗng) - newPassword (độ dài 8-20	Dưới đây là bảng phân hoạch tương đương (Equivalence Partitions) chi tiết cho tính năng "Forgot password and password reset". Để đảm bảo tính bao phủ (coverage) cao nhất cho báo cáo Domain Testing của bạn, ngoài các điều kiện bạn đã nêu, tôi đã bổ sung thêm một số phân hoạch liên quan đến tính hợp lệ của định dạng và thời gian sống của OTP (những yếu tố cốt lõi khi triển khai xác thực OTP thực tế). Bảng Phân hoạch Tương đương (Equivalence Partitions) Trường dữ liệu Mã phân hoạch Điều kiện phân hoạch (Mô tả) Loại phân hoạch Kết quả kỳ vọng emailEP_E1 Định dạng hợp lệ, tồn tại trong cơ sở dữ liệu Hợp lệ Hệ thống gửi OTP, chuyển sang bước nhập mãEP_E2 Định dạng hợp lệ, KHÔNG tồn tại trong cơ sở dữ liệu Không hợp lệ Hiển thị lỗi (vd: Email không tồn tại)EP_E3 Sai định dạng (thiếu @, sai domain, v.v.) Không hợp lệ Hiển thị lỗi validate định dạng emailEP_E4 Bị bỏ trống (Rỗng/Null) Không hợp lệ Hiển thị lỗi yêu cầu nhập trường nàyresetToken (OTP 4 số)EP_T1 Chứa đúng 4 chữ số, khớp với mã đã gửi và còn hạn Hợp lệ Chấp nhận mã, cho phép đổi mật khẩuEP_T2 Chứa đúng 4 chữ số, nhưng sai mã (không khớp) Không hợp lệ Hiển thị lỗi sai mã OTPPEP_T3 Mã đúng nhưng đã hết hạn (Expired) Không hợp lệ Hiển thị lỗi mã đã hết hạnEP_T4 Độ dài không đúng 4 ký tự (< 4 hoặc > 4) Không hợp lệ Hiển thị lỗi validate độ dài OTPPEP_T5 Chứa ký tự không phải là số (chữ cái, ký tự đặc biệt) Không hợp lệ Hiển thị lỗi validate định dạng sốEP_T6 Bị bỏ trống (Rỗng/Null) Không hợp lệ Hiển thị lỗi yêu cầu nhập trường nàynewPasswordEP_P1 Độ dài 8-20 ký tự, có chứa số và ký tự đặc biệt Hợp lệ Đổi mật khẩu thành côngEP_P2 Độ dài < 8 ký tự Không hợp lệ Hiển thị lỗi mật khẩu quá ngắnEP_P3 Độ dài > 20 ký tự Không hợp lệ Hiển thị lỗi mật khẩu quá dàiEP_P4 Độ dài 8-20 ký tự,	INCOMPL ETE	AI phân hoạch đầy đủ về mặt lý thuyết nhưng thiếu xem xét mã nguồn thực tế và bối cảnh bảo mật của hệ thống SUT. AI bỏ sót phân hoạch cho việc "OTP bị trả về trực tiếp trong response body" của API forgot-password và thiếu phân hoạch cho trường hợp đổi mật khẩu mới thành rỗng "".	Sinh viên bổ sung phân hoạch tương đương cho trường hợp mật khẩu mới để trống và cập nhật thêm phản hồi lỗi bảo mật của OTP vào thiết kế ca kiểm thử miền trị.
---	--	--------------------	--	---

ký tự hợp lệ, quá ngắn <8, quá dài >20, rỗng, thiếu ký tự đặc biệt/số) Hãy liệt kê rõ ràng dưới dạng bảng kèm mã phân hoạch"	nhưng thiếu số hoặc ký tự đặc biệt Không hợp lệ Hiển thị lỗi mật khẩu không đủ độ phức tạp EP_P5 Bị bỏ trống (Rỗng/Null) Không hợp lệ Hiển thị lỗi yêu cầu nhập trường này Lưu ý khi phối hợp các phân hoạch (Test Case Design) Khi viết test case thực tế cho báo cáo bằng AI, bạn không nên kết hợp nhiều phân hoạch không hợp lệ (Invalid) vào cùng một test case. Nguyên tắc là: Positive Test Case: Kết hợp tất cả các phân hoạch hợp lệ (EP_E1 + EP_T1 + EP_P1) để tạo ra luồng thành công (Happy Path). Negative Test Case: Giữ tất cả các trường khác ở trạng thái hợp lệ, và chỉ áp dụng một phân hoạch không hợp lệ cho trường đang muốn kiểm thử để đảm bảo hệ thống bắt đúng lỗi của trường đó. Bạn có muốn chúng ta tiếp tục chuyển sang phân tích Giá trị biên (Boundary Value Analysis) cho độ dài của trường newPassword (để tìm ra các giá trị biên như 7, 8, 20, 21) nhằm hoàn thiện luôn phần thứ hai của yêu cầu đề bài không?			
Tool: Gemini 3.5 Flash Thời gian: 21:01 25/06/2026 Prompt: " Tôi đang thực hiện kỹ thuật phân tích giá trị biên (BVA) cho tính năng "Discount coupons". Một mã giảm giá cụ thể (ví dụ: SAVE10) quy định giá trị đơn hàng tối thiểu (min_order_amount) là 300,000 đ để có thể áp	Dưới đây là phân tích giá trị biên (Boundary Value Analysis - 3-point) cho điều kiện tổng tiền đơn hàng (total_amount) áp dụng mã giảm giá với ngưỡng biên là 300,000 đ. Giá định hệ thống quản lý tiền tệ dưới dạng số nguyên (Integer/Long) hoặc số thực có độ chính xác cao (BigDecimal) với đơn vị nhỏ nhất được phép là 1 đ. 1. Bảng xác định các giá trị kiểm thử (3-point BVA) Điểm biên Giá trị kiểm thử (total_amount) Phân loại Kết quả kỳ vọng Min- 299,999 đ Không hợp lệ (Invalid) Hệ thống từ chối áp dụng coupon, báo lỗi chưa đủ điều kiện. Min 300,000 đ Hợp lệ (Valid) Hệ thống chấp nhận áp dụng coupon. Min+ 300,001 đ Hợp lệ (Valid) Hệ thống chấp nhận áp dụng coupon. 2. Giải thích ý nghĩa của từng giá trị đối với logic áp dụng coupon Giá trị Min- (299,999 đ): Ý nghĩa: Đây là điểm dữ liệu nằm ngay sát dưới vạch đích. Nó kiểm tra xem hệ thống có vô	VALID	Áp dụng chính xác kỹ thuật phân tích giá trị biên 3-point BVA cho giá trị tối thiểu của đơn hàng (Min-, Min, Min+) xoay quanh điểm biên 300,000 đ.	Sinh viên giữ nguyên các điểm biên nhưng ghi nhận sự khác biệt thực tế khi chạy test case: hệ thống bị lỗi biên toán tử > (chặn đúng mức 300,000 đ) thay vì >=.

dụng. Hãy giúp tôi xác định các điểm biên (3-point BVA) cho biến <code>total_amount</code> (tổng tiền đơn hàng) xoay quanh biên 300,000 đ: 1. Xác định các giá trị kiểm thử: Min-, Min, Min+ 2. Giải thích ý nghĩa của từng giá trị đối với logic áp dụng coupon."	tình cho phép các đơn hàng xấp xỉ đạt yêu cầu được lọt qua hay không. Mục tiêu bắt lỗi (Off-by-one error): Phát hiện lỗi lập trình nếu developer sử dụng sai toán tử, ví dụ như dùng vòng làm tròn không chính xác trước khi so sánh, hoặc hệ thống backend không xử lý nghiêm ngặt điều kiện chặn dưới. Giá trị Min (300,000 đ): Ý nghĩa: Đây là điểm giới hạn chính xác (boundary). Nó đại diện cho số tiền tối thiểu vừa đủ để thỏa mãn điều kiện. Mục tiêu bắt lỗi: Kiểm tra xem developer sử dụng toán tử $\geq$ (lớn hơn hoặc bằng) hay $>$ (lớn hơn). Nếu developer dùng mã code if (<code>total_amount > 300000</code>), test case này sẽ thất bại (bị từ chối), giúp bạn phát hiện ra lỗi logic (bug) ngay tại điểm chạm. Giá trị Min+ (300,001 đ): Ý nghĩa: Đây là điểm dữ liệu nằm ngay sát trên vạch đích. Mục tiêu bắt lỗi: Test case này đảm bảo rằng khi giá trị thực sự vượt qua biên, logic phần mềm vẫn hoạt động đúng như thiết kế ở vùng hợp lệ, xác nhận rằng logic chặn dưới không vô tình chặn luôn cả các giá trị lớn hơn nó một đơn vị nhỏ nhất. Lưu ý bổ sung về nghiệp vụ E-commerce: Trong trường hợp SUT (EShop) giới hạn bước nhảy giá trị (step size) của sản phẩm ở mức hàng nghìn đồng (ví dụ: không có sản phẩm nào lẻ 1 đ, bước nhảy nhỏ nhất là 1,000 đ), bạn có thể điều chỉnh độ phân giải của giá trị biên thành: Min-: 299,000 đ Min: 300,000 đ Min+: 301,000 đ Tuy nhiên, về mặt kiểm thử logic mức mã nguồn (white-box hoặc grey-box testing), việc sử dụng đơn vị chênh lệch 1 đ vẫn là phương pháp chính xác nhất để phủ kín các toán tử so sánh.			
Tool: Gemini 3.5 Flash Thời gian: 14:32 28/06/2026 Prompt: " Tôi muốn	Dưới đây là bảng phân tích phân hoạch tương đương và danh sách các ca kiểm thử (Test Cases) được thiết kế cho chức năng Quản lý danh mục (Category Management) thông qua API. 1. Phân hoạch tương đương (Equivalence Partitions) Trường dữ	INCOMPL ETE	AI đề xuất các ca kiểm thử CRUD cơ bản nhưng bỏ sót lỗi ràng buộc khóa ngoại của SQLite khi	Sinh viên bổ sung ca kiểm thử kiểm tra tính toàn vẹn dữ liệu khi xóa danh mục đang có

thiết kế test cases cho chức năng Quản lý danh mục gồm các API: - POST /api/categories { name } - PUT /api/categories/:id { name } - DELETE /api/categories/:id Hãy gợi ý các phân hoạch tương đương cho: - Tên danh mục (name): Hợp lệ, để trống, trùng tên đã có. - ID danh mục (id): Có tồn tại, không tồn tại. Và thiết kế các ca kiểm thử tương ứng"	liệuMã phân hoạchĐiều kiện phân hoạchLoại phân hoạchKết quả kỳ vọngTên danh mục (name)EP_N1Chuỗi ký tự hợp lệ, chưa tồn tại trong hệ thốngHợp lệChấp nhận xử lýEP_N2Chuỗi rỗng hoặc chỉ chứa khoảng trắng (Empty/Null)Không hợp lệBáo lỗi dữ liệu đầu vào (400 Bad Request)EP_N3Chuỗi ký tự trùng lặp với một danh mục đã tồn tạiKhông hợp lệBáo lỗi xung đột dữ liệu (409 Conflict / 400 Bad Request)ID danh mục (id)EP_ID1ID hợp lệ, đang tồn tại trong cơ sở dữ liệuHợp lệTìm thấy đối tượng, cho phép thao tácEP_ID2ID không tồn tại trong cơ sở dữ liệuKhông hợp lệBáo lỗi không tìm thấy (404 Not Found)2. Thiết kế Test Cases cho từng APIDựa trên nguyên tắc kết hợp các phân hoạch, dưới đây là các ca kiểm thử cụ thể cho từng API.API: POST /api/categories (Tạo mới danh mục)API này chỉ phụ thuộc vào trường name trong body request.Test Case IDTên ca kiểm thửĐiều kiện kiểm thử (Phân hoạch áp dụng)Kết quả kỳ vọng (HTTP Status & Body)TC_CAT_POST_01Tạo danh mục mới thành côngÁp dụng EP_N1HTTP 201 Created. Trả về thông tin danh mục vừa tạo kèm ID.TC_CAT_POST_02Tạo danh mục thất bại do tên rỗngÁp dụng EP_N2HTTP 400 Bad Request. Thông báo lỗi: Tên danh mục không được để trống.TC_CAT_POST_03Tạo danh mục thất bại do trùng tênÁp dụng EP_N3HTTP 409 Conflict (hoặc 400). Thông báo lỗi: Tên danh mục đã tồn tại.API: PUT /api/categories/:id (Cập nhật danh mục)API này phụ thuộc vào cả id (path variable) và name (body request). Chúng ta sẽ giữ một trường ở trạng thái hợp lệ và thử nghiệm các phân hoạch của trường còn lại.Test Case IDTên ca kiểm thửĐiều kiện kiểm thử (Phân hoạch áp dụng)Kết quả kỳ vọng (HTTP Status & Body)TC_CAT_PUT_01Cập nhật danh		xóa danh mục (SQLite mặc định tắt check khóa ngoại) và không đi sâu vào kiểm tra trùng tên ở mức Database.	sản phẩm liên kết và phát hiện lỗi khóa ngoại thực tế trong mã nguồn.
--	---	--	---	--

	mục thành côngÁp dụng EP_ID1 + EP_N1HTTP 200 OK. Trả về thông tin danh mục đã cập nhật.TC_CAT_PUT_02Cập nhật thất bại do ID không tồn tạiÁp dụng EP_ID2 + EP_N1HTTP 404 Not Found. Thông báo lỗi: Không tìm thấy danh mục.TC_CAT_PUT_03Cập nhật thất bại do tên rỗngÁp dụng EP_ID1 + EP_N2HTTP 400 Bad Request. Thông báo lỗi: Tên danh mục không được để trống.TC_CAT_PUT_04Cập nhật thất bại do tên mới bị trùngÁp dụng EP_ID1 + EP_N3 (Trùng với tên của một ID khác)HTTP 409 Conflict. Thông báo lỗi: Tên danh mục đã tồn tại.API: DELETE /api/categories/:id (Xóa danh mục)API này chỉ phụ thuộc vào id (path variable).Test Case IDTên ca kiểm thửĐiều kiện kiểm thử (Phân hoạch áp dụng)Kết quả kỳ vọng (HTTP Status & Body)TC_CAT_DEL_01Xóa danh mục thành côngÁp dụng EP_ID1HTTP 204 No Content (hoặc 200 OK). Danh mục bị xóa khỏi hệ thống.TC_CAT_DEL_02Xóa thất bại do ID không tồn tạiÁp dụng EP_ID2HTTP 404 Not Found. Thông báo lỗi: Không tìm thấy danh mục.Bạn có muốn bổ sung thêm kỹ thuật Phân tích giá trị biên (Boundary Value Analysis) cho độ dài tối đa của trường name để đảm bảo hệ thống xử lý tốt các chuỗi ký tự quá dài không?			
Tool: Gemini 3.5 Flash Thời gian: 22:53 01/07/2026 Prompt: " Tôi cần áp dụng Domain Testing và Boundary Value Analysis cho tính năng tìm kiếm sản phẩm trên ứng dụng di	Đây là một hướng tiếp cận rất thực tế và chuyên sâu. Đối với tính năng tìm kiếm, việc kết hợp kiểm thử độ dài chuỗi (chiều rộng) và kiểm thử bảo mật/ký tự đặc biệt (chiều sâu) sẽ giúp bạn có một bộ test case toàn diện.Vì bạn chưa cung cấp giới hạn độ dài tối đa của ô tìm kiếm, tôi sẽ thiết lập một giả định tiêu chuẩn thường thấy trong các hệ thống e-commerce:Độ dài tối thiểu: 1 ký tự.Độ dài tối đa: 255 ký tự.Dưới đây là chi tiết áp dụng các kỹ thuật kiểm thử.1. Phân hoạch tương đương (Equivalence Partitioning)Chúng ta sẽ chia phân	INVALID	AI mặc định hệ thống tìm kiếm an toàn và xử lý lỗi đồng bộ dưới dạng JSON API. AI hoàn toàn bỏ qua việc phân tích lỗ hổng SQL Injection thô trực tiếp trong câu lệnh SQLite LIKE	Sinh viên sửa đổi toàn bộ bảng test case của AI bằng cách bổ sung các test case kiểm tra SQL Injection thực tế (' OR 1=1 --), nhập ký tự đặc biệt phá vỡ cú pháp SQL ('), và cập

động. Endpoint backend là: GET /api/products? search=... Trường đầu vào là ô nhập tìm kiếm "search". Hãy thiết kế các phân hoạch tương đương và giá trị biên cho độ dài chuỗi tìm kiếm, đặc biệt lưu ý kiểm tra các lỗ hổng bảo mật liên quan đến SQL Injection (vì backend dùng SQLite) hoặc ký tự đặc biệt dùng trong SQL LIKE như % và _."	hoạch theo hai khía cạnh: Độ dài chuỗi và Nội dung chuỗi. Phân hoạch theo Độ dài (Length) Mã Điều kiện phân hoạch Loại Kết quả kỳ vọng EP_L1 1 <= Độ dài <= 255 Hợp lệ Thực hiện tìm kiếm và trả về kết quả hoặc mảng rỗng. EP_L2 Độ dài = 0 (Để trống / Rỗng) Không hợp lệ (hoặc Xử lý đặc biệt) Báo lỗi yêu cầu nhập từ khóa, hoặc trả về toàn bộ sản phẩm (tùy spec). Giả định ở đây là báo lỗi. EP_L3 Độ dài > 255 Không hợp lệ Báo lỗi chuỗi tìm kiếm quá dài (400 Bad Request) hoặc client tự động cắt chuỗi. Phân hoạch theo Nội dung (Content & Security) Mã Điều kiện phân hoạch Loại Kết quả kỳ vọng EP_C1 Chuỗi ký tự chữ và số thông thường (Alphanumeric) Hợp lệ Trả về kết quả khớp với từ khóa. EP_C2 Chuỗi chứa ký tự Wildcard của SQL (% , _) Hợp lệ (Cần Escape) Hệ thống coi % và _ là ký tự text bình thường (Literal text), không phải toán tử SQL. EP_C3 Chuỗi chứa Payload SQL Injection cơ bản (Boolean based) Độc hại Hệ thống encode hoặc sử dụng Parameterized Queries. Trả về kết quả tìm kiếm cho chính chuỗi độc hại đó (thường là rỗng), không báo lỗi SQL Syntax. EP_C4 Chuỗi chứa Payload phá vỡ câu lệnh (Stacked queries / Union) Độc hại Hệ thống không thực thi câu lệnh thứ hai. Ứng dụng không bị crash hoặc lộ dữ liệu bảng khác. 2. Phân tích Giá trị biên (Boundary Value Analysis - 3-point) Áp dụng cho chiều dài của chuỗi đầu vào (length), tập trung vào 2 vách ngăn là 1 và 255. Điểm biên Giá trị kiểm thử (Độ dài chuỗi) Phân loại Kết quả kỳ vọng Min-0 ký tự Không hợp lệ Backend từ chối request (HTTP 400) hoặc yêu cầu nhập lại. Min+1 ký tự (VD: "A") Hợp lệ Thực hiện tìm kiếm bình thường. Min+2 ký tự (VD: "Ab") Hợp lệ Thực hiện tìm kiếm bình thường. Max-254 ký tự Hợp lệ Thực hiện tìm kiếm bình thường. Max+255 ký tự Hợp lệ Thực hiện tìm kiếm bình		'%\${search}%' và bỏ qua lỗi Response định dạng HTML thay vì JSON làm hỏng UI mobile.	nhật kết quả thực tế bị lỗi HTML thô/hiển thị sai dữ liệu.
---	---	--	--	---

	thường.Max+256 ký tựKhông hợp lệBackend từ chối request, trả về lỗi 400 Bad Request.3. Thiết kế Test Case Chuyên sâu (Security & Wildcards)Đối với SQLite và lỗi SQL Injection qua toán tử LIKE, hệ thống thường ghép chuỗi theo dạng:SELECT * FROM products WHERE name LIKE '%{search}%'Nếu backend không sử dụng Parameterized Queries hoặc không Escape ký tự đúng cách, hacker có thể thao túng câu truy vấn. Dưới đây là các Test Case cụ thể bạn cần đưa vào báo cáo:Nhóm 1: Kiểm thử SQL Wildcards (Ký tự đại diện)Mục tiêu: Đảm bảo người dùng có thể tìm kiếm các sản phẩm thực sự chứa ký tự % (ví dụ: "Áo giảm 20%") mà không bị backend hiểu nhầm là ký tự đại diện cho mọi chuỗi.TC_SEARCH_WILD_01: * Input: search=%Mục đích: Ký tự % trong SQL LIKE đại diện cho "0 hoặc nhiều ký tự". Nếu backend không escape (thành \%), query sẽ trở thành LIKE '%%', hệ thống sẽ trả về toàn bộ sản phẩm.Kỳ vọng: Chỉ trả về các sản phẩm có chứa ký tự % trong tên/mô tả.TC_SEARCH_WILD_02:Input: search=_Mục đích: Ký tự _ đại diện cho "đúng 1 ký tự". Nếu không escape, query LIKE '%_%' sẽ khớp với mọi chuỗi có ít nhất 1 ký tự.Kỳ vọng: Chỉ trả về các sản phẩm có chứa ký tự _ (underscore).Nhóm 2: Kiểm thử SQL Injection trên SQLiteMục tiêu: Bẻ gãy cấu trúc câu lệnh LIKE hiện tại và chèn thêm điều kiện hoặc câu lệnh mới.TC_SEARCH_SQLI_01 (Boolean Based):Input: search=iphone%' OR '1'='1Mục đích: Payload này cố gắng biến query thành: ... WHERE name LIKE '%iphone%' OR '1'='1%. Vì '1'='1' luôn đúng, nếu bị lỗi SQLi, hệ thống sẽ trả về toàn bộ database thay vì chỉ trả về "iphone".Kỳ vọng: Không xảy ra SQLi. Hệ thống tìm kiếm một sản phẩm có chuỗi literal iphone%' OR '1'='1. Trả về mảng rỗng (0 kết quả).TC_SEARCH_SQLI_02 (Đóng nháy kép/đơn sớm):Input: search=" (Hai			
--	--	--	--	--

	dấu nhảy đơn) hoặc search="Mục đích: Kiểm tra xem backend có bị văng lỗi Uncaught Exception (500 Internal Server Error) do lỗi cú pháp SQL (SQL Syntax Error) hay không. Lỗi 500 là dấu hiệu rõ ràng nhất của việc đầu vào không được sanitize. Kỳ vọng: Trả về 200 OK với kết quả tìm kiếm rỗng, không văng lỗi 500.TC_SEARCH_SQLI_03 (Union Base/Data Exfiltration):Input: search=' UNION SELECT 1, sqlite_version(), 3 --Mục đích: SQLite hỗ trợ toán tử UNION. Payload này cố gắng đọc thông tin phiên bản SQLite hoặc dữ liệu từ bảng khác (như bảng users). Cú pháp -- dùng để comment phần còn lại của câu lệnh gốc.Kỳ vọng: Ứng dụng xử lý an toàn (sử dụng Prepared Statements). Dữ liệu nhạy cảm không bị rò rỉ ra ngoài qua response body.			
--	---	--	--	--

4. Tổng kết Độ chính xác AI

Tổng hợp verdict từ Mục 3 và điền vào bảng dưới.

Chỉ số	Số lượng	Tỉ lệ
Tổng artifact AI sinh đã audit	5	
VALID (đúng, dùng nguyên)	2	40%
INVALID (sai; loại bỏ)	1	20%
INCOMPLETE (chấp nhận sau khi sửa)	2	40%

5. Kết luận — Khi nào nên / không nên dùng AI?

Viết 80–150 chữ mô tả pattern quan sát được. AI mạnh ở đâu? AI sai ở đâu? Khuyến nghị của bạn cho việc dùng AI trong loại công việc này?

- AI rất mạnh trong việc tự động hóa khởi tạo khung xương kiểm thử, gợi ý nhanh các phân hoạch tương đương (EP) lý thuyết dựa trên mô tả API cấp cao. Tuy nhiên, AI thường sai sót khi đối mặt với mã nguồn chi tiết dưới backend, lỗi biên toán tử so sánh (như > thay vì >=), lỗ hổng bảo mật SQL Injection thô hay sự không khớp định dạng phản hồi API.
- Khuyến nghị: Nên dùng AI để hỗ trợ lập dàn ý, brainstorm các kịch bản kiểm thử trong phần chuẩn bị. Không nên lạm dụng AI để sinh test cases trực tiếp mà không rà soát mã nguồn thực tế (Static Testing) và chạy kiểm thử động thực tế trên ứng dụng.

6. Mandatory Disclosure (dán nguyên văn)

"[Test case / script / dataset / báo cáo] này được sinh phiên bản đầu bởi Gemini 3.5 Flash; tôi đã rà soát và chỉnh sửa bằng test case Domain & BVA, bổ sung các lỗi SQL Injection và các lỗi so sánh biên thực tế của coupon. AI Audit Report chi tiết đính kèm ở Phụ lục A. Tôi cam đoan không dùng AI để sinh bất kỳ artifact nào thuộc danh mục bị cấm."

Chữ ký

Họ tên sinh viên (in hoa):	HUỖNH SĨ LUÂN
MSSV:	23127086
Lớp / Khoá:	23CLC01
Môn học:	CS423 / CSC13003 – Kiểm chứng Phần mềm
Giảng viên:	Lâm Quang Vũ
Ngày:	07/07/2026
Chữ ký:	Luân

Tham khảo

- Kharbach, M. (2026). AI Use Policy Templates for Higher Education. CC BY-NC-SA 4.0.
- ISTQB Foundation Level Syllabus (latest version).
- Hardman, P. (2025). A Post-AI Learning Taxonomy.
- Fuster Rabella, M. (2025). OECD Education Working Paper No. 338.
- Perkins, M., Roe, J., & Furze, L. (2025). AI Assessment Scale.
- Anthropic (2025). Building reliable AI test agents — engineering blog.
- DeepEval & Promptfoo documentation — testing frameworks for LLM systems.